FUNCTIONALITY COVERAGE ASSESSMENT

# Next-Gen ESDS WAF — Coverage vs. Enlight Pratihar (WAAP) Specification

This document maps every functionality in the Enlight Pratihar HLD/LLD against what our shipped WAF delivers today, what is on our committed 7-phase roadmap, and what depends on other internal teams. Assessed against the live codebase.

Prepared by: WAF Engineering · Basis: Pratihar HLD v1.0 + LLD v1.0 vs. Next-Gen ESDS WAF (Phases 0–6) · Status: honest engineering assessment

---

**Executive summary.** The Pratihar documents describe a full Web-Application-and-API-Protection (WAAP) **platform vision**. Against that vision, our WAF today: the **core protection engine, TLS/proxy layer, rate-limiting, ML anomaly detection, multi-tenant control plane and observability are available and working now**. The remaining items are almost entirely **already on our committed roadmap (Phase 6–7)** — API security (OpenAPI/GraphQL/gRPC), outbound DLP, post-quantum TLS, positive-security ML and compliance report packs are planned features, not missing capabilities. The **Hansa / Garud / Jatayoo ecosystem integrations** depend on those (internal ESDS) product teams, and a set of items — long-term archival, regulatory report packs, Kafka bus and the microservice split — are **out of scope for the WAF engine**: they belong to the compliance, storage or reporting layers, not the firewall itself (and are not missing security features).

| 42 | 15 | 34 | 3 | 6 |
|---|---|---|---|---|
| Available now | Partial (usable, enhancing) | On roadmap (Phase 6–7) | Needs internal team | Not required / out of scope |

● AVAILABLE — shipped & working today
● PARTIAL — usable now, enhancement planned
● ROADMAP — committed Phase 6 / Phase 7
● NEEDS TEAM — depends on internal ESDS product
● NOT REQUIRED — out of scope for the WAF engine

## 🌐 1 · Traffic Ingestion & Delivery (Reverse Proxy)

The L7 data-plane that terminates and forwards traffic.

| FUNCTIONALITY | STATUS | NOTES |
|---|---|---|

| | | |
|---|---|---|
| **L7 reverse proxy — HTTP/1.1, HTTP/2, WebSocket** | AVAILABLE | Full proxy with keep-alive upstream pooling & buffering. |
| **HTTP/3 (QUIC)** | AVAILABLE | Live & verified; same WAF pipeline & cert store as TCP. |
| **TLS 1.2 / 1.3 termination + SNI multi-tenant routing** | AVAILABLE | rustls, ALPN h2/h1; per-domain cert selection by SNI. |
| **Origin health checks + failover + circuit breaker** | AVAILABLE | Active + passive checks, half-open recovery. |
| **Load balancing (round-robin, least-conn, IP-hash)** | PARTIAL | Weighted + consistent-hash ring pending. |
| **Post-quantum TLS (hybrid X25519 + Kyber)** | ROADMAP P6 | Config hooks present; handshake wiring in Phase 6. |
| **Mutual TLS to origin (client-cert to upstream)** | ROADMAP | Origin server-cert validated today; client-cert to upstream planned. |
| **Static-asset caching & response compression** | ROADMAP | Marked optional in the spec; low priority. |

## 🛡️ 2 · Detection & Prevention Engines

Signature, anomaly and protocol defenses — the heart of the WAF.

| FUNCTIONALITY | STATUS | NOTES |
|---|---|---|
| **OWASP CRS signature engine (SecLang/ModSecurity-compatible)** | AVAILABLE | 2,541 rules, compiled to a bytecode VM; runs live. |
| **SQLi / XSS detection (libinjection)** | AVAILABLE | Dedicated detectors beyond regex. |
| **Input normalization / transformations** | AVAILABLE | Full CRS transform pipeline. |
| **HTTP request-smuggling / desync defense** | AVAILABLE | CL.TE / TE.CL / TE.TE rejection. |
| **RFC validation, size / method / header limits** | AVAILABLE | Enforced with correct status codes. |
| **Anomaly-scoring + hard-block modes** | AVAILABLE | Collaborative scoring and immediate block. |

| | | |
|---|---|---|
| **ML anomaly detection (Isolation Forest) + payload classifier** | AVAILABLE | Global anomaly + attack classifier, wired to the pipeline. |
| **Paranoia levels & verdict fusion (Allow/Block/Challenge/Log)** | PARTIAL | PL rule-gating + 4 verdicts; per-PL thresholds & a LIMIT verdict pending. |
| **Virtual patching (CVE-mapped rules)** | PARTIAL | Mechanism present; per-CVE pack workflow + signed emergency fast-channel on roadmap. |
| **Positive-security model (per-app learned parameters, ONNX) + drift detection** | ROADMAP | Per-route ML baselining is planned; ONNX runtime already integrated. |
| **ESDS / India-specific threat-research signature packs** | ROADMAP | Engine ready; content authoring needs ESDS threat-research input. |

## 🤖 3 · Bot & Abuse Management

Automated-threat and abuse defense.

| FUNCTIONALITY | STATUS | NOTES |
|---|---|---|
| **IP reputation (allow / block / suspect + feed ingestion)** | AVAILABLE | CIDR-based, allowlist precedence. |
| **Distributed rate limiting (Redis sliding window + local fallback)** | AVAILABLE | Atomic LUA sliding window; degrades to in-memory. |
| **Self-hosted JS Proof-of-Work challenge (HMAC clearance cookie)** | AVAILABLE | Sovereignty-friendly; no foreign dependency. |
| **L4 anti-DDoS (eBPF/XDP kernel drops)** | AVAILABLE | Kernel-level SYN/flood mitigation module. |
| **JA3 / JA4 TLS fingerprinting** | PARTIAL | Config & matching present; fingerprint-extraction pipeline to be completed. |
| **CAPTCHA tiers & multi-dimensional rate-limit keys (session/JWT/API-key/geo)** | PARTIAL | Native PoW + IP/site keys today; self-hosted CAPTCHA + richer keys planned. |
| **Weighted bot scoring, header/Markov heuristics, ASN reputation, good-bot verify** | ROADMAP | Behavioral-biometric scoring model in the plan. |

| | | |
|---|---|---|
| **Named abuse playbooks (credential-stuffing, OTP-bombing, scraping…)** | ROADMAP | Covered indirectly today via rate-limit + scanner blocking. |

## 🔌 4 · API Security (WAAP)

The dedicated API-protection layer — largely a Phase 6 build.

| FUNCTIONALITY | STATUS | NOTES |
|---|---|---|
| **Secure response-header injection & hop-by-hop stripping** | AVAILABLE | Per-site configurable. |
| **JSON/XML structural limits (size, header count)** | PARTIAL | Byte/header limits enforced; deep JSON-depth / XXE structural guard pending. |
| **OpenAPI schema import & enforcement · API auto-discovery** | ROADMAP P6 | "API auto-discovery" is an explicit Phase 6 deliverable. |
| **GraphQL firewall (depth / complexity / schema / introspection)** | ROADMAP P6 | Explicit Phase 6 deliverable. |
| **gRPC firewall (proto introspection, per-method limits)** | ROADMAP P6 | Explicit Phase 6 deliverable. |
| **Edge JWT / OAuth2 validation on customer traffic + JWKS rotation** | ROADMAP P6 | Basic JWT-validator plugin exists; full edge enforcement in Phase 6. |
| **BOLA / IDOR access-pattern anomaly detection** | ROADMAP | Pairs with positive-security & API discovery. |
| **Response-path DLP / PII masking (card, Aadhaar, PAN, mobile)** | ROADMAP P6 | "Outbound DLP" is an explicit Phase 6 deliverable (detection exists; masking action pending). |

## 💥 5 · Layer-7 DDoS Protection

| FUNCTIONALITY | STATUS | NOTES |
|---|---|---|
| **Connection-rate admission control (per-IP sliding window + temp block)** | AVAILABLE | Fixed-threshold admission at ingress. |

| | | |
|---|---|---|
| **Slow-attack (Slowloris) policing** | PARTIAL | Header-dribble & H2 flood bounded; slow-body (RUDY) byte-rate pending. |
| **Adaptive RPS baselining (EWMA) & graduated "storm mode" auto-mitigation** | ROADMAP | Adaptive throttling on the plan; JS-challenge escalation primitive already exists. |

## 🔐 6 · TLS & Certificate Management

| FUNCTIONALITY | STATUS | NOTES |
|---|---|---|
| **ACME auto-issuance & renewal (HTTP-01, TLS-ALPN-01)** | AVAILABLE | Verified against LE staging; DNS-01 pending. |
| **Per-site certs, hot rotation (zero-downtime), manual upload + validation** | AVAILABLE | Hot-swap on next handshake. |
| **Dedicated management-console TLS (replaceable device cert)** | AVAILABLE | Isolated admin listener. |
| **Private CA (self-signed + downloadable root CA)** | PARTIAL | Enterprise-CA enrolment (SCEP/EST, CCA-India) pending. |
| **HSM / Vault private-key custody** | ROADMAP · LOW | Enterprise-deployment option for high-assurance environments; default is secured on-disk keys (0600, atomic writes). |
| **OCSP stapling** | ROADMAP | Minor add. |

## 🗄️ 7 · Control Plane, Data Model & Governance

| FUNCTIONALITY | STATUS | NOTES |
|---|---|---|
| **PostgreSQL data model (tenants, sites, rules, users, API keys, ML profiles)** | AVAILABLE | Complete core schema. |
| **Hard multi-tenant isolation (row-level security)** | AVAILABLE | FORCE RLS + non-superuser role. |
| **RBAC (5 roles, resource×action) + JWT / OIDC / machine API keys** | AVAILABLE | Exceeds the spec's 4-role model. |

| | | |
|---|---|---|
| **Append-only, HMAC-chained tamper-evident audit log** | AVAILABLE | Durable, broadly wired. |
| **Config hot-sync to edge + Management REST API (/api/v1)** | AVAILABLE | Changes reach edges well within the <30s target. |
| **SAML SSO + enforced admin MFA · hierarchical policy inheritance** | PARTIAL | OIDC live; SAML/MFA enforcement & global→app policy inheritance planned. |
| **HA control plane — Raft active/active, degrade to last-known-good** | PARTIAL | Raft module present; multi-node active-active hardening in Phase 7. |
| **Policy publish pipeline (draft→shadow→sign→rollback) + ETag concurrency** | ROADMAP | Config validation/dry-run exists; signed-bundle staging pipeline planned. |
| **Microservice decomposition (7 separate services)** | NOT REQUIRED | Delivered as one control-plane binary — same functions, simpler ops; can split for scale later. |

## 📈 8 · Event Pipeline, Storage & Observability

| FUNCTIONALITY | STATUS | NOTES |
|---|---|---|
| **ClickHouse event storage (90-day hot) + Threat Search (searchable history)** | AVAILABLE | 90-day tier matches spec; tenant-scoped search. |
| **Live security-event / log streaming to console** | AVAILABLE | Real-time SSE log viewer. |
| **Real-time dashboard (traffic, attack breakdown, KPIs)** | AVAILABLE | 15-route enterprise console. |
| **Prometheus metrics + Grafana dashboards** | AVAILABLE | Metrics export + provisioned Grafana. |
| **Alerting engine (attack-spike, repeat-offender, critical) + AI Copilot** | AVAILABLE | LLM assistant supports in-country (Ollama) models. |
| **Alert channels (Slack, Webhook live; Email, SMS, Teams planned) · role-tuned views** | PARTIAL | Channel fan-out framework in place. |

| | | |
|---|---|---|
| **Enriched event envelope (asn, ja4, trace_id) for APM/SIEM correlation** | ROADMAP | Core fields present today. (7-year archival & Kafka bus → see "Not required".) |

## 🚀 9 · Deployment, HA/DR & Compliance

| FUNCTIONALITY | STATUS | NOTES |
|---|---|---|
| **Docker + single-node on-prem deployment · India-resident (self-hosted)** | AVAILABLE | Live in production. |
| **Kubernetes deployment (manifests)** | PARTIAL | Raw manifests today; Helm chart + operator = Phase 7. |
| **Sub-millisecond p99 added latency** | AVAILABLE | Verified. |
| **SaaS PoP fleet · dedicated hardened OVA (packaging)** | ROADMAP P7 | Productization phase. |
| **Global active-active cluster** | ROADMAP · LOW | Future scalability enhancement; Raft-based HA already present, single/multi-node works today. |
| **1M RPS/cluster · 99.99% multi-DC availability · fail-open/closed per tenant** | ROADMAP P7 | Performance certification is a Phase 7 exit criterion. |
| **SOC2 / PCI-DSS / ISO 27001 readiness** | ROADMAP P7 | On the Phase 7 hardening list. |
| **180-day retention + DPDP per-tenant encryption keys** | ROADMAP | Data-protection controls. (CERT-In/RBI/PCI report packs → see "Not required".) |

### 🔗 What we would need from other internal (ESDS) teams

These are integrations with **other Enlight products**, not WAF features. We can integrate on demand once the counterpart teams expose their contracts — today we already forward events in standard CEF/Syslog/Webhook formats, which is enough for basic interop.

- **Enlight Hansa** (SIEM/SOAR) — native CEF/JSON forwarding + bidirectional block-list (SOAR) push with signed service token. *Needs Hansa's ingest + block-list API.*
- **Enlight Garud** (APM) — WAF-overhead latency correlation via `traceparent` propagation. *Needs Garud's trace contract.*
- **Enlight Jatayoo** — web-to-database attack-chain correlation. *Needs Jatayoo's correlation interface.*

## ⚪ Not Required / Out of Scope for the WAF Engine

These are compliance-layer, storage, deployment or scalability concerns — **not missing security features**. The WAF supplies the data/evidence they build on.

| FUNCTIONALITY (FROM PRATIHAR) | WHY IT'S OUT OF SCOPE FOR THE WAF ENGINE |
|---|---|
| **7-year event archive** | Long-term retention belongs to the storage / SIEM layer. The WAF keeps 90-day hot, searchable history and streams events out for archival. |
| **CERT-In incident-report generator** | A compliance / reporting module (or SIEM) generates regulator packs from the WAF's audit evidence & event data — not a firewall-engine function. |
| **RBI report templates** | Compliance report pack (reporting layer). |
| **PCI report templates** | Compliance report pack (reporting layer). |
| **Kafka event bus** | The direct proxy → ClickHouse pipeline already delivers searchable history + live streaming. Kafka only adds hyperscale multi-consumer fan-out; can be added later without product change. |
| **7-service microservice split** | One hardened control-plane binary delivers the same functions with simpler, more secure operations; can be decomposed for independent scaling when volume demands. |

*Compliance note: for regulated (BFSI) customers, long-term archival and CERT-In / RBI / PCI **reporting** remain contractual obligations — they are delivered by the platform's **compliance / SIEM layer (e.g. Enlight Hansa) and external storage**, built on the tamper-evident audit trail and event data the WAF produces. The obligation is met at the platform level; it simply isn't the firewall engine's job.*

*Assessment is against the current codebase; a few items the internal roadmap listed as "done" (e.g., JA4 fingerprint extraction, per-app positive-security ML, SAML/MFA enforcement) are shown here as **Partial / Roadmap** because the shipped code does not yet fully implement them — stated conservatively so the assessment holds up to technical review.*